SEFU HMIS — Data Protection Impact Assessment (DPIA)

Kenya Digital Health Agency (DHA) & Office of the Data Protection Commissioner (ODPC) Compliance

Statutory Basis: Section 31 of the Kenya Data Protection Act 2019 & Data Protection (General) Regulations 2021

System Classification: Health Information System (HIS) & Electronic Medical Record (EMR)

Document Classification: Regulatory Compliance Document (Required Upload $\le$ 2MB)

■ 1. Assessment Overview & Document Control

DPIA Attribute	Detail
Document Title	Data Protection Impact Assessment (DPIA) for Sensitive Health Data Processing
System Name	SEFU Hospital Management Information System (SEFU HMIS)
System Version	Release 5.0 (Build 2026-Kenya-DHA)
Document Version	1.0 (Statutory Filing Standard)
Software Vendor / Processor	SEFU Health Systems Limited (Data Processor)
Healthcare Facility	Partner Health Facilities & Hospitals (Data Controllers)
Lead DPO Assessor	Certified Data Protection Officer (ODPC Registered Lead)
Effective Date	November 2026
Review Frequency	Annually or upon significant architectural/processing changes

---

■ 2. Description of the Processing Operations

2.1 Nature and Context of Health Data Processing

SEFU HMIS processes **sensitive personal data** as defined under Section 2 and Section 44 of the Kenya Data Protection Act 2019 (specifically physical and mental health status, medical history, reproductive health, diagnostic test outcomes, and biometric data).

2.2 Roles of Parties under the Kenya Data Protection Act 2019

- **The Healthcare Facility (Hospital/Clinic):** Acts as the **Data Controller**. The hospital determines the clinical purposes and legal basis for collecting and processing patient health data during medical consultations.
- **SEFU Health Systems Limited (Software Vendor):** Acts as the **Data Processor**. SEFU provides, hosts, maintains, and supports the software platform on behalf of the hospital in accordance with a formal Data Processing Agreement (DPA).

■ 3. Patient Health Data Lifecycle & Data Flow

```
[1. Collection] ■■■ [2. Processing] ■■■ [3. Storage & At-Rest] ■■■ [4. Transmission] ■■■ [5.
Retention & Disposal]
• Patient Intake • Consultations • MariaDB Database • TLS 1.3 / HTTPS • 7-Year Statutory Period
• Triage Vitals • Prescriptions • Encrypted Uploads Vault • Encrypted Webhook • Secure Overwrite Purge
• Lab/Rad Requests • Lab Parameters • Immutable Audit Logs • Local LAN Traffic • De-identification
```

3.1 Data Categories Collected & Processed

Category	Specific Data Elements	Legal Basis for Processing
Patient Demographics	Full name, National ID / Alien ID, DOB, age, gender, address, next of kin, telephone, email.	Direct provision of medical care; Patient consent (Section 30, DPA 2019).
Clinical Health Data	Presenting symptoms, vital signs, physical exam findings, diagnoses (ICD-10), clinical notes.	Medical diagnosis & provision of healthcare treatment (Section 44(1)(c)).
Specialty Health Data	Antenatal LMP/EDD, obstetric history (GPA), pediatric developmental milestones, physiotherapy pain ratings.	Clinical specialty care; Provision of maternal and child healthcare.
Diagnostic Data	Pathology lab parameters (blood, urine, biopsy), radiology reports (X-ray, ultrasound).	Diagnostic investigations necessary for patient treatment.
Pharmaceutical Data	Prescribed medications, dosage, dispensing logs, drug allergies.	Patient clinical safety and medication management.
Financial & Insurance Data	Itemized hospital bills, payment modes (Cash/M-Pesa), Social Health Authority (SHA) member numbers.	Fulfillment of hospital treatment contract & insurance claims settlement.
System Security Data	User login IDs, staff roles, IP addresses, audit timestamps, 2FA OTP codes.	Information security and statutory audit compliance (Section 41, DPA 2019).

■■ 4. Assessment of Necessity and Proportionality

1. **Lawful Basis:** The processing of sensitive health data is lawful under Section 30 and Section 44(1)(c) of the Kenya Data Protection Act 2019, which explicitly permits the processing of health data for medical purposes by or under the responsibility of a healthcare professional.
2. **Data Minimization:** SEFU HMIS enforces data minimization principles. Only clinical fields strictly necessary for patient care, triage, and statutory health reporting are mandated.
3. **Purpose Limitation:** Health data stored in the HMIS is used strictly for direct clinical care, patient billing, and authorized statutory reporting. It is never sold, shared with unauthorized third parties, or processed for commercial profiling.

■ 5. Privacy Risk Assessment & Safeguards Matrix

A comprehensive threat modeling assessment was conducted to identify potential privacy risks to patients and the technical/operational safeguards implemented to neutralize them:

Identified Privacy Risk	Likelihood	Impact	Overall Risk	Technical & Operational Safeguard Implemented	Residual Risk
1. Unauthorized Access by Staff / Clerks	Medium	High	**High**	Granular **Role-Based Access Control (RBAC)** restricting access to authorized roles only. Front desk cannot see clinical notes; laboratory clerks cannot modify prescriptions.	**LOW**

2. Credential Stuffing & Password Compromise	Medium	High	**High**	Enforced **Multi-Factor Authentication (MFA / 2FA via Email OTP)**, 8+ character mixed-character regex, and **Bcrypt hashing** (`$2y$10$...`).	**LOW**
3. Man-in-the-Middle Eavesdropping in Transit	Low	High	**Medium**	Mandatory **TLS 1.2 / 1.3 encryption (HTTPS)** on all endpoints; automatic HTTP-to-HTTPS redirect; `Strict-Transport-Security` headers.	**LOW**
4. Inadvertent Exposure via Unattended Screens	High	Medium	**Medium**	Automated **Session Idle Timeout (7200 seconds / 2 hours)** terminating active sessions on abandoned terminals; 5-min session ID rotation.	**LOW**
5. SQL Injection Database Breach	Low	Critical	**High**	100% of database interactions utilize **CodeIgniter Active Record parameterized queries**; zero dynamic concatenated SQL execution.	**LOW**
6. Insider Data Tampering / Covert Deletion	Low	High	**Medium**	Comprehensive **Audit Trail (`logs` table)** capturing every Insert, Update, and Delete action with staff ID and role attribution. Log deletion strictly locked.	**LOW**
7. Catastrophic Data Loss (Hardware / Ransomware)	Low	Critical	**High**	Enterprise **3-2-1 Backup Strategy**, automated hourly/daily backups, immutable SHA-256 checksum verification, and tested **Disaster Recovery Plan (DRP)**.	**LOW**
8. Unlawful Cross-Border Data Transfer	Low	High	**Medium**	**Kenya Data Localization:** All primary databases and backup servers reside within designated Kenyan infrastructure or compliant tier-3 cloud regions.	**LOW**

■■ 6. Data Subject Rights Fulfillment Architecture

SEFU HMIS provides specific administrative and technical workflows to satisfy patient rights under Part IV of the Kenya Data Protection Act 2019:

1. **Right of Access (Section 26):** Patients can review their medical visit history, prescriptions, and invoices directly via the authenticated **Patient Portal** (`/site/userlogin`), or request an official medical record export from Medical Records.
2. **Right to Rectification (Section 28):** Clinical officers can update incorrect demographic or contact information, with the prior state preserved in the system audit trail.
3. **Right to Erasure / De-Identification (Section 40):** While statutory medical record laws mandate retention of clinical charts, patient contact identifiers can be de-identified/anonymized upon justified request after statutory clinical retention periods elapse.
4. **Data Portability (Section 34):** Patients can export their health encounters and laboratory results in standardized digital formats (PDF vouchers / JSON summaries).

■■ 7. Data Retention, Archival & Secure Disposal Policy

- **Active Clinical Records:** Retained for a minimum of **7 years** from the date of the last patient encounter (mandated by the Kenya Medical Practitioners and Dentists Council guidelines).
- **Pediatric Records:** Retained until the patient attains **25 years of age** (7 years past the age of majority).
- **Maternity & Obstetric Records:** Retained for **25 years** to support longitudinal developmental and obstetric continuity.
- **Secure Disposal Method:** Upon authorization by the Hospital Medical Board, expired physical files undergo cross-cut incineration/shredding. Digital records undergo cryptographic cryptographic sanitization (DoD 5220.22-M overwrite standards) to prevent forensic data recovery.

■ 8. Statutory Consultation & Sign-Off

The Data Protection Impact Assessment confirms that the technical, organizational, and physical security measures embedded within **SEFU HMIS** provide adequate and robust safeguards to protect sensitive personal health information against unauthorized access, loss, or misuse.

DPIA Outcome:

APPROVED — RESIDUAL PRIVACY RISKS ARE ACCEPTABLE AND ADEQUATELY CONTROLLED.

Signed and Certified by:

Data Protection Officer (ODPC Registered Lead)

Chief Technology Officer (CTO)

SEFU Health Systems Limited — Kenya Digital Health Agency (DHA) Compliance Filing